Kinvecta

SERIE PARA QUIENES FACILITAN · INMERSIÓN TÉCNICA B

Contenedores, escaneo y el pipeline de CI/CD

Una caja, escaneada una vez, firmada y confiable en todos lados donde corre.



Video de 24 minutos

Etapas 2–5

DevSecOps para cargas de IA

Kinvecta

HOY

Al terminar, las personas participantes podrán…

1. Explicar DevSecOps, las imágenes y dónde corren los contenedores
2. Leer un Dockerfile endurecido y un reporte de escaneo
3. Recorrer la línea de CI/CD y sus puntos de control
4. Aplicar reglas de red de denegar por defecto, en ambas direcciones

CAPÍTULOS · 24 MIN

a escala



Kinvecta

POR QUÉ IMPORTA

Tres problemas que resuelve un buen pipeline

01

“En mi laptop sí funcionaba”

El agente se comporta distinto en staging y nadie sabe decir qué se liberó exactamente.

02

“40 hallazgos HIGH. ¿Y ahora qué?”

Los escáneres gritan. Los equipos corrigen lo que no urge, o apagan el escáner.

03

“El escáner fue el ataque”

Marzo de 2026: una Action de escaneo secuestrada robó secretos de CI de los pipelines que la ejecutaron.

La pregunta de esta inmersión técnica: **¿Cómo liberamos una caja confiable y seguimos confiando en ella?**

Kinvecta

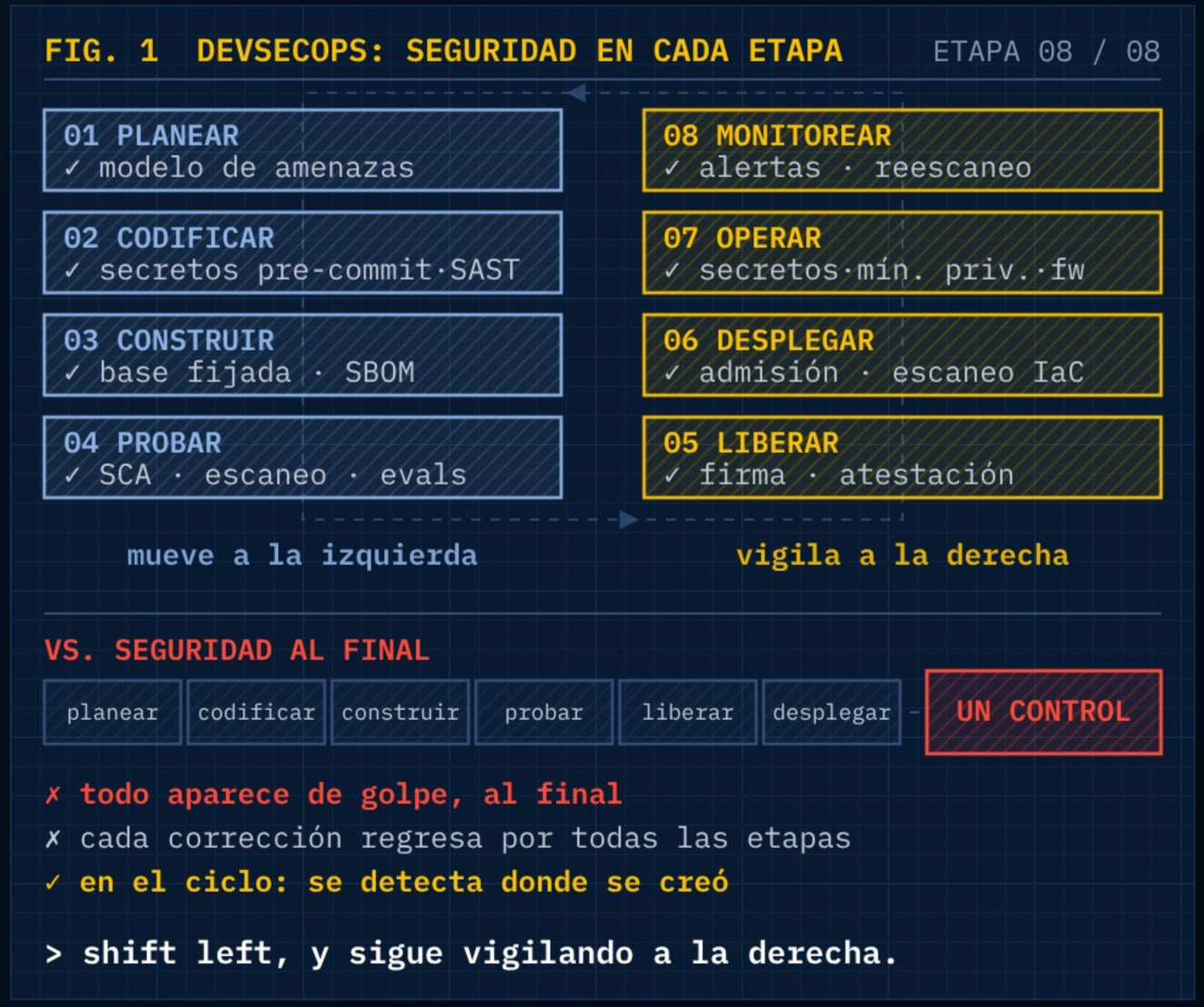
DEVSECOPS

Seguridad en cada etapa, no solo al final

Llevar la seguridad al inicio
Modelo de amenazas y escaneos mientras el cambio es pequeño y barato

Controlar la liberación
Escanear, firmar y atestar antes de liberar

Seguir vigilando a la derecha
Alertas en tiempo de ejecución, reescaneos y mínimo privilegio ya en producción



Kinvecta

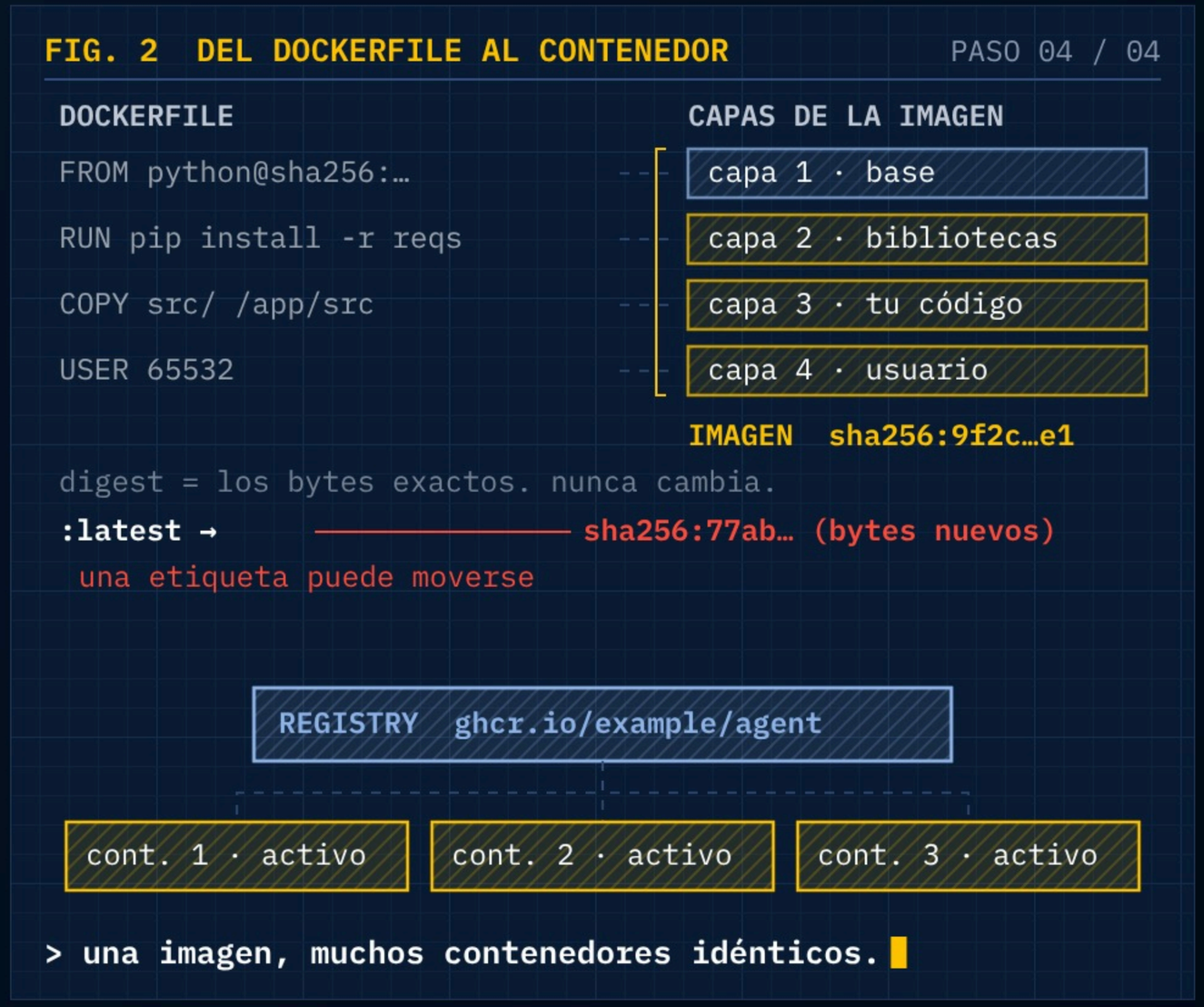
LOS CONTENEDORES, EXPLICADOS

Se construye una vez, corre en todos lados

Imagen
La caja sellada: tu código, el runtime y las bibliotecas. Nunca cambia.

Contenedor
La caja abierta y en ejecución. De una imagen pueden correr muchos.

Registry y digest
El almacén. El digest (sha256) es la identidad real de la caja; una etiqueta puede moverse.



Kinvecta

DÓNDE CORREN LOS CONTENEDORES

La misma caja, distintos barcos

El mismo digest en todos lados
Laptop, servidor, serverless, clúster o edge

Cambia quién parcha qué
Los servicios administrados parchan más; tu imagen, código y llaves siguen siendo tuyos

Código no confiable: sandbox
gVisor, Firecracker o Kata



Kinvecta

ENDURECER LA IMAGEN

Empaca solo lo que la app necesita

Base mínima, fijada por digest
Sin shell ni gestor de paquetes; la misma base que escaneaste

Build multietapa
Compiladores, caché y git se quedan en el build y nunca se envían

Sin secretos, sin root
Las llaves llegan en ejecución; la app corre como usuario común

FIG. 4 ENDURECE EL DOCKERFILE — CORRECCIÓN 04 / 04

~~FROM python:latest~~
~~COPY . /app~~
~~RUN pip install -r reqs.txt~~
~~ENV API_KEY=sk-live-…~~
~~CMD ["python","app.py"]~~

DATOS DE LA CAJA	
CVEs	12
tamaño	60 MB
secretos	0
root (ilustrativo)	no

1 Base mínima, fijada por digest
FROM …/python@sha256:…

2 Multietapa: las herramientas de build se quedan
COPY --from=build /app /app

3 Sin secretos en la imagen
inyéctalo al ejecutar (con rm sigue en una capa)

4 Usuario sin root
USER 65532

> menos cosas en la caja, menos cosas que fallen.

Kinvecta

LEE UN DOCKERFILE ENDURECIDO

Dos etapas, una base fijada, sin llaves

```
# syntax=docker/dockerfile:1
# etapa de build: tiene pip y compiladores
FROM cgr.dev/chainguard/python:latest-dev@sha256:<builder> AS build
WORKDIR /app
COPY requirements.txt .
RUN python -m venv /app/venv && \
    /app/venv/bin/pip install --require-hashes -r requirements.txt
COPY src/ ./src/
# etapa de runtime: sin shell, sin pip, sin root
FROM cgr.dev/chainguard/python:latest@sha256:<runtime>
COPY --from=build /app/venv /app/venv
COPY --from=build /app/src /app/src
USER 65532
ENTRYPOINT ["python", "-m", "src.server"]
# aquí no hay API keys: se inyectan en ejecución
```

OPCIONES DE IMAGEN BASE

Docker Hardened Images
Gratis y abiertas desde 17 dic 2025; SBOM + SLSA

Chainguard
Basada en Wolfi; gratis solo :latest

Google distroless
Solo runtime, sin shell; :nonroot

Red Hat UBI
Basada en RHEL; soporte en OpenShift

Alpine · Debian-slim
Buenas bases, no endurecidas

Bitnami
De pago desde sep 2025: audita

Kinvecta

SECRETOS

Las llaves no viven en la imagen ni en el repo

Las capas son permanentes
Una llave borrada en un paso posterior sigue en la capa anterior

Un gestor, no un archivo
Vault (u OpenBao), AWS Secrets Manager, Azure Key Vault, Google Secret Manager

De vida corta, inyectados, rotados
Identidad de la carga de trabajo, inyección en ejecución, rotación programada



Kinvecta

ESCANEO

Como filtros de aeropuerto

Una amenaza por máquina

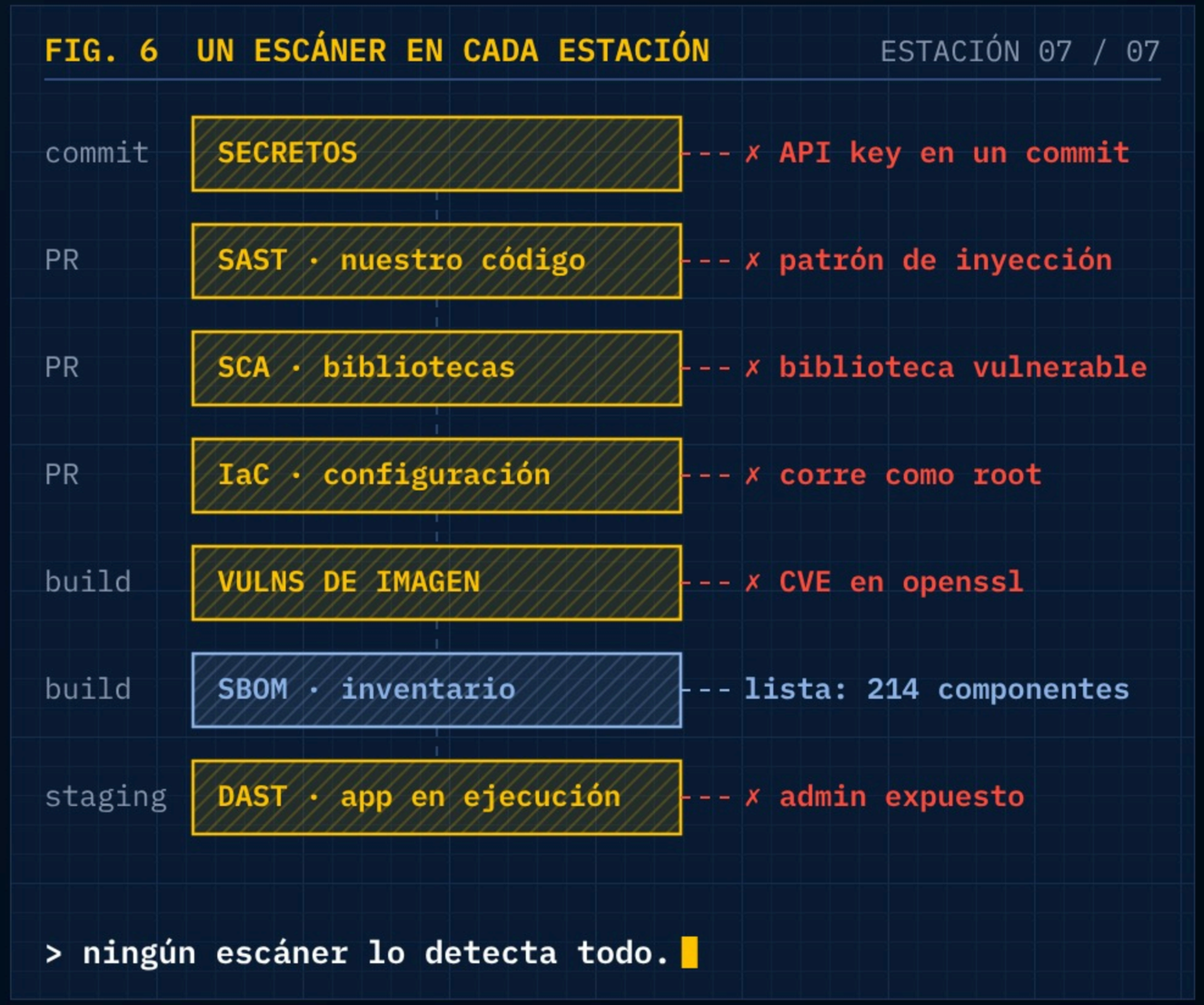
Secretos, nuestro código, bibliotecas, configuración, la imagen, la app en ejecución

Escanea temprano

Las revisiones en commit y pull request son el lugar más barato para corregir

Vuelve a escanear después

Aparecen CVEs nuevos después de liberar; los registries reescanean las imágenes guardadas



Kinvecta

REFERENCIA DE HERRAMIENTAS · 1 DE 2

Escáneres por categoría

CATEGORÍA	CÓDIGO ABIERTO	COMERCIAL / EN LA NUBE
Vulns de imagen + SBOM	Trivy · Grype · Syft	Docker Scout · Anchore Enterprise · Snyk Container
Secretos	Gitleaks · TruffleHog · Betterleaks (nuevo, mar 2026)	Escaneo de secretos de GitHub + protección de push
SAST (nuestro código)	Semgrep CE · CodeQL (repos públicos) · SonarQube Community Build	Semgrep AppSec · GitHub Code Security · SonarQube Server
SCA + actualizaciones	OWASP Dependency-Check · OSV-Scanner · Renovate · Dependabot	Snyk Open Source · Socket
IaC + configuración	Trivy config (absorbió tfsec) · Checkov · KICS	Cortex Cloud (antes Prisma Cloud) · Wiz (ahora de Google)
DAST + malware	ZAP · ClamAV · YARA	Aqua · Cortex Cloud · Wiz

Versiones al 20 oct 2026: Trivy 0.76.0 · Grype 0.121.0 · Syft 1.55.0 · Gitleaks 8.30.1 · Semgrep 1.182.0. Ejemplos, no recomendaciones.

Kinvecta

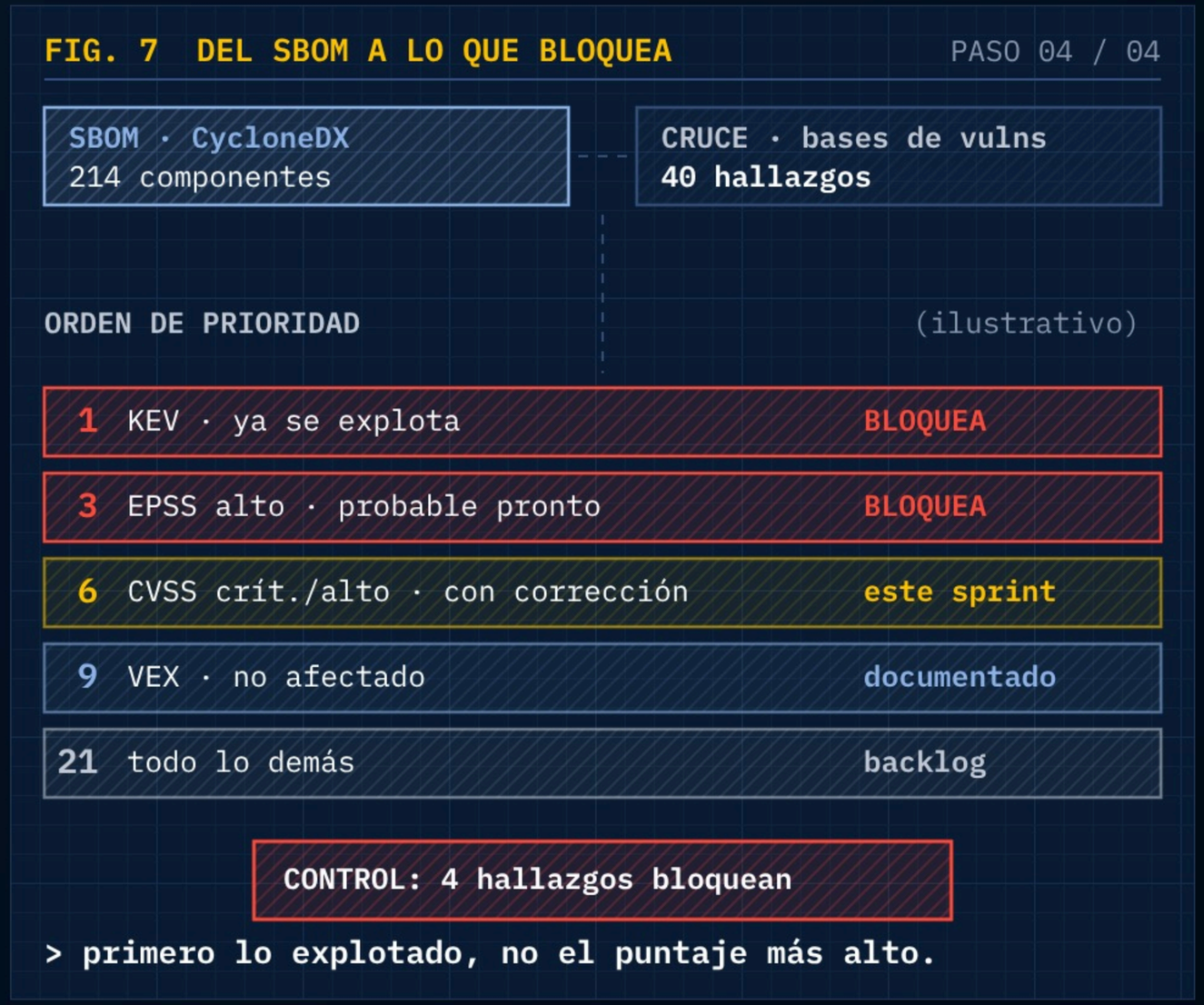
TRIAJE

Corrige primero lo que ya se explota

CVE · CVSS
El ID de la falla y qué tan grave podría ser (0–10)

EPSS · KEV
Qué tan probable es que se explote pronto; la lista de CISA de fallas que ya se explotan

VEX
Una nota legible por máquina: “no afectado, porque…”, para reducir falsas alarmas



Kinvecta

FIRMA Y ADMISIÓN

Demuestra que es la caja que escaneamos

Firma el digest

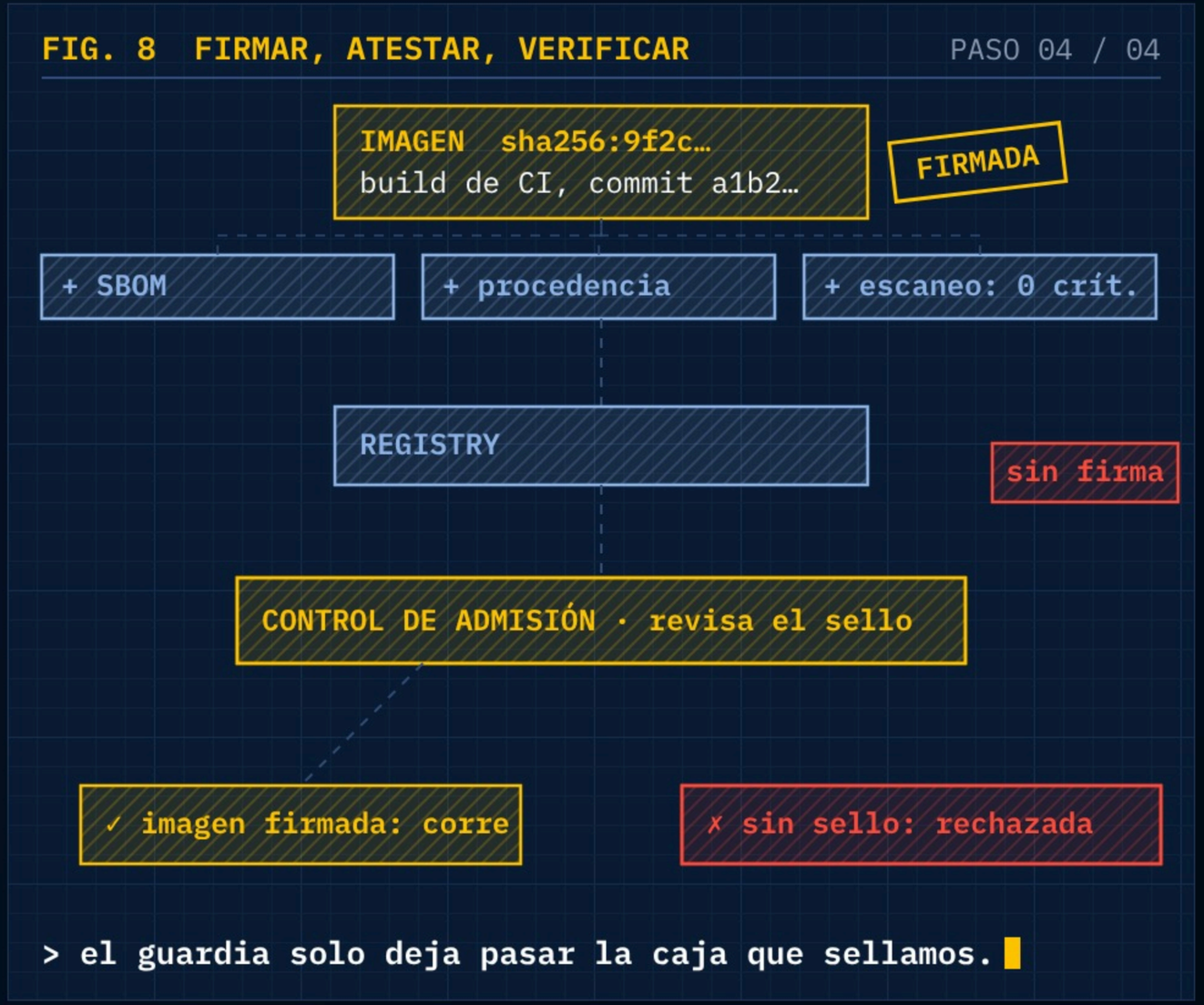
Cosign (keyless: la identidad de CI) o Notation con tu propia PKI

Atesta

Adjunta al digest el SBOM, la procedencia (SLSA) y los resultados del escaneo

Verifica en la puerta

El control de admisión rechaza todo lo que no esté firmado o verificado



Kinvecta

REFERENCIA DE HERRAMIENTAS · 2 DE 2

Firma, registries, la línea y el runtime

CATEGORÍA	CÓDIGO ABIERTO	COMERCIAL / EN LA NUBE
Firma + procedencia	Sigstore Cosign v3 · Notation · SLSA / in-toto	Atestaciones de artefactos de GitHub (actions/attest)
Registries	Harbor (con Trivy integrado) · Project Quay (Clair)	GHCR · ECR · ACR · Artifact Registry · Artifactory + Xray
Políticas + admisión	Kyverno (graduado en CNCF, mar 2026) · OPA Gatekeeper · Sigstore policy-controller	Kubernetes ValidatingAdmissionPolicy viene integrado
CI/CD + GitOps	Jenkins · Tekton + Chains · Argo CD · Flux	GitHub Actions · GitLab CI · Azure DevOps
Secretos	OpenBao · External Secrets Operator · Secrets Store CSI	Vault (IBM) · AWS Secrets Manager · Azure Key Vault · Google Secret Manager
Runtime + monitoreo	Falco · Tetragon · Convenciones GenAI de OpenTelemetry (aún no estables)	Sensores CNAPP (Aqua, Cortex Cloud, Wiz) · Langfuse · Datadog · Splunk

Versiones al 20 oct 2026: Cosign 3.1.4 · Kyverno 1.19.2 · Argo CD 3.5.6 · Flux 2.9.6. Ejemplos, no recomendaciones.

Kinvecta

CI/CD

Una línea de ensamble con inspecciones

Un build, muchos entornos

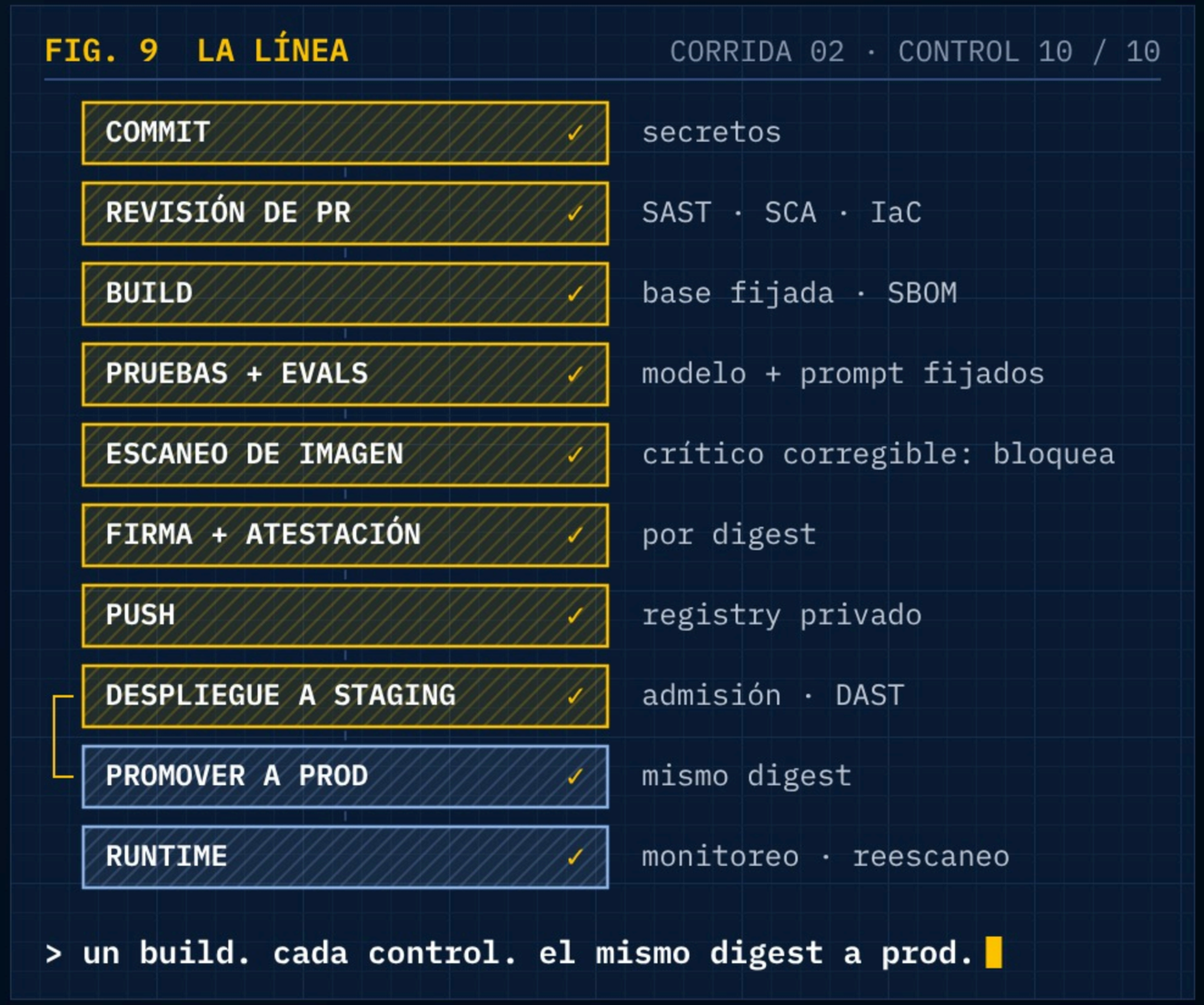
Staging y producción corren el mismo digest; nunca reconstruyas para producción

Romper el build

Falla ante críticos con corrección, cualquier KEV o secretos en una capa

Excepciones con fecha límite

Un responsable, una fecha de vencimiento y una nota VEX, o los equipos apagan el escáner



Kinvecta

LEE EL PIPELINE

Un fragmento de GitHub Actions, anotado

```
permissions: { contents: read }
steps:
  - uses: actions/checkout@<SHA> # v6
  - run: semgrep scan --config p/owasp-top-ten --error
  - name: Build, carga local (aún sin push)
  - name: Escaneo de imagen con Trivy (el punto de control)
    uses: aquasecurity/trivy-action@<SHA> # v0.36.0
    with: { severity: "CRITICAL,HIGH",
            ignore-unfixed: true, exit-code: "1" }
  - name: Push (solo si pasa el escaneo)
  - run: cosign sign --yes "$IMAGE" # $IMAGE = …@sha256:digest
  - run: cosign attest --yes --type cyclonedx \
         --predicate sbom.cdx.json "$IMAGE"
  - uses: actions/attest@<SHA> # v4 · procedencia SLSA
```

1 Mínimo privilegio
Cada job pide los permisos extra que necesita

2 Fija cada action por SHA completo
<SHA> = marcador: llénalo desde cada página de Releases, o deja que Renovate lo haga

3 Escanea antes del push
exit-code 1 rompe el build

4 Firma el digest
Adjúntale el SBOM y la procedencia

Kinvecta

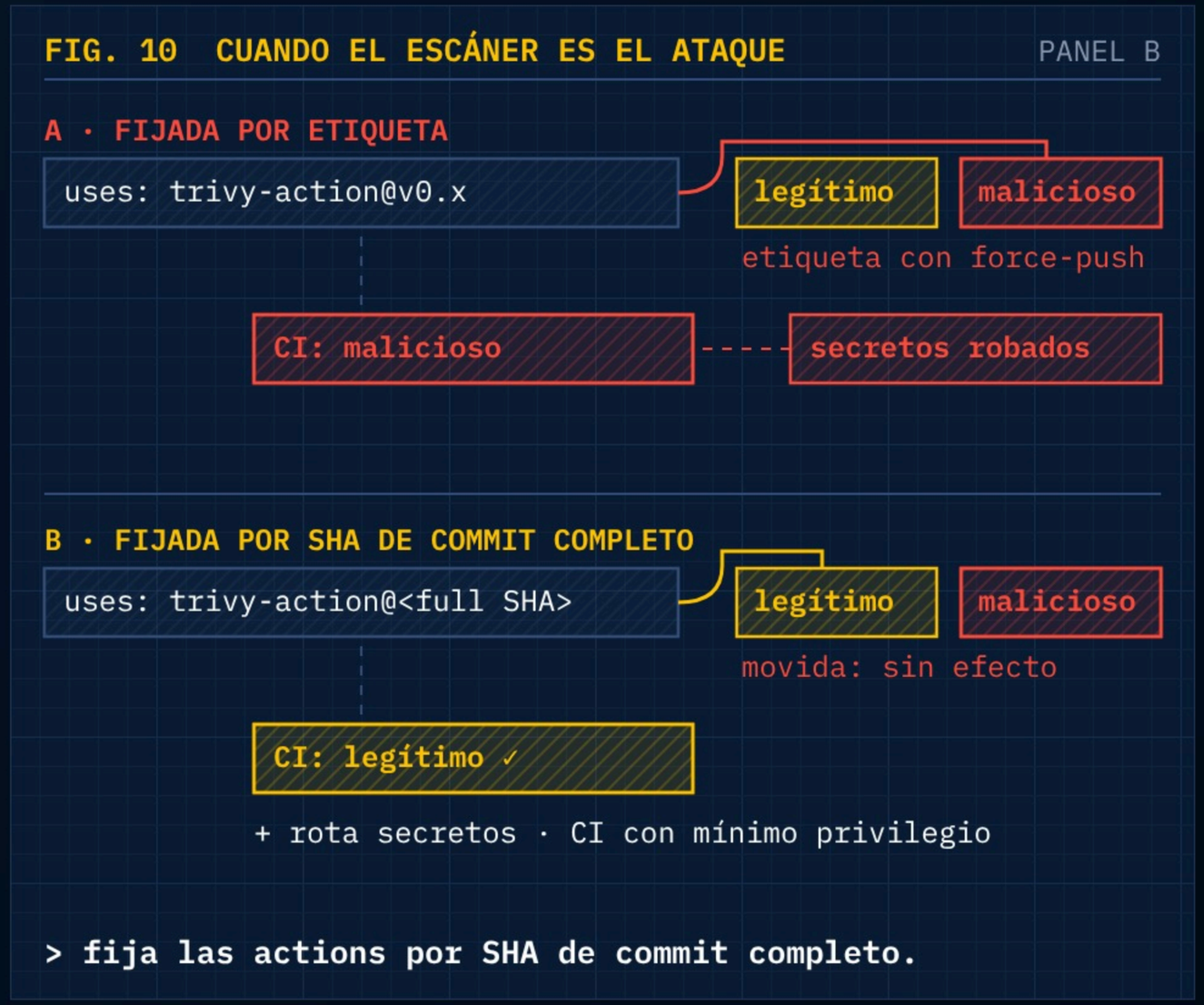
LECCIÓN DE CADENA DE SUMINISTRO

Tu escáner también es una dependencia

Marzo de 2026
Atacantes movieron etiquetas de trivy-action y setup-trivy para robar secretos

Fija por SHA de commit completo
Las etiquetas se mueven; un SHA no. GitHub puede exigirlo.

CI con mínimo privilegio
Credenciales OIDC de vida corta, permisos mínimos, rotación tras un compromiso



Kinvecta

FIREWALLS

Denegar por defecto, en ambas direcciones

Capas, de afuera hacia adentro

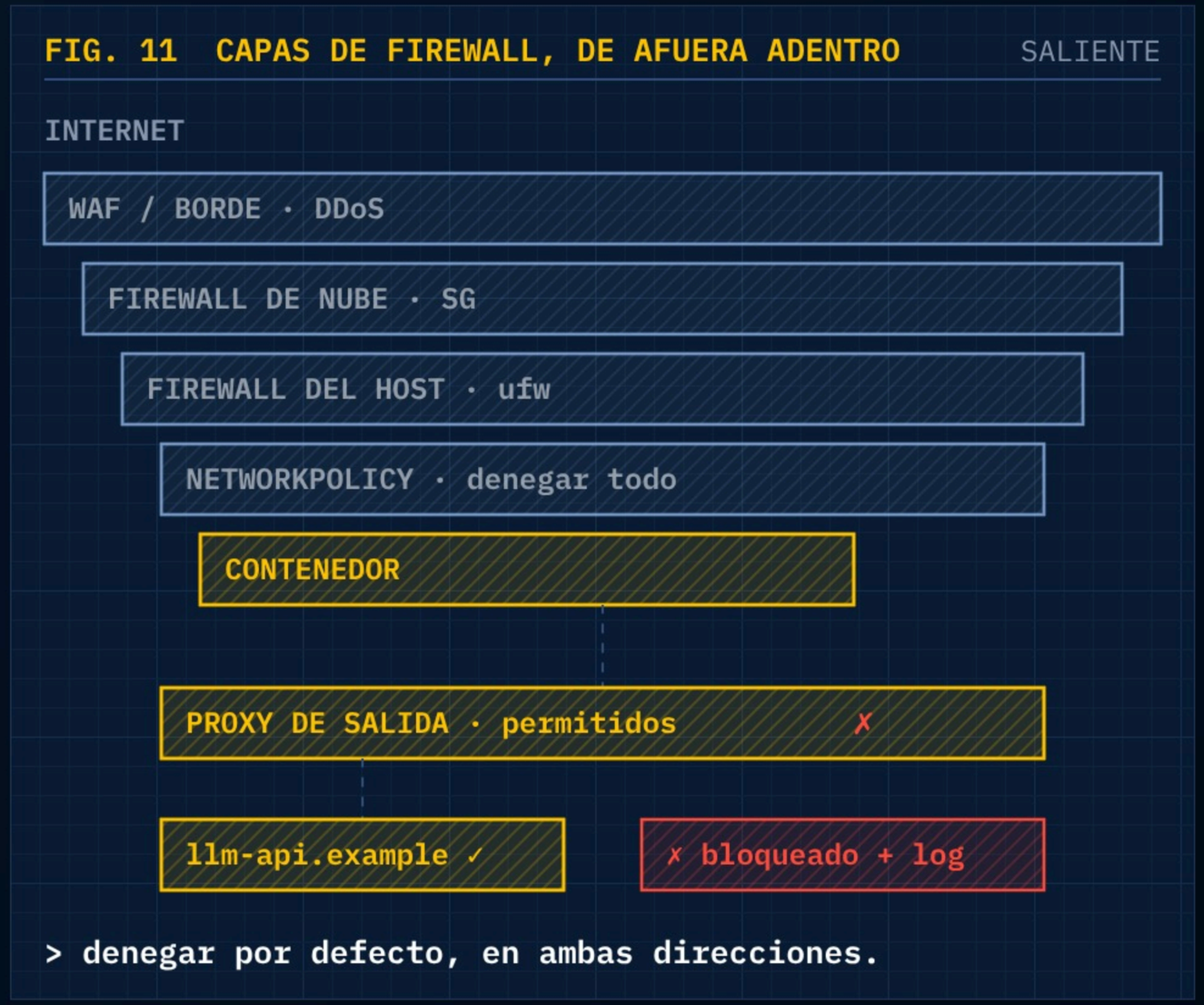
WAF, firewall de nube, firewall del host, NetworkPolicy

Revisa la trampa de Docker

Los puertos publicados se saltan ufw; usa DOCKER-USER o enlaza a localhost

Tráfico de salida (egress)

Lista de permitidos: solo la API del LLM y backends aprobados; lo demás se registra



Kinvecta

CONTROLES DE RED · REFERENCIA DE HERRAMIENTAS

Cada capa y sus herramientas

CAPA	QUÉ HACE	HERRAMIENTAS Y SERVICIOS COMUNES
1 · Borde: WAF + DDoS	Filtra web entrante; limita endpoints LLM costosos	AWS WAF + Shield · Azure Front Door WAF · Google Cloud Armor · Cloudflare · Akamai
2 · Firewall de nube	Permite o niega por IP, puerto y protocolo	AWS Security Groups + NACLs · Azure NSGs · Google VPC firewall rules
3 · Firewall / proxy de salida	Una salida, lista de permitidos por host, logs	AWS Network Firewall · Azure Firewall · Google Cloud NGFW · Squid · Envoy
4 · Firewall del host	Filtra en el servidor; ojo: Docker lo salta	nftables / iptables · firewalld · ufw con la cadena DOCKER-USER
5 · NetworkPolicy	Denegar por defecto entre pods; sin host	La aplica el CNI: Calico · Cilium · Antrea
6 · Política FQDN + mesh	Salida por DNS; TLS mutuo entre servicios	Cilium toFQDNs · GKE FQDN policies · Istio · Linkerd

DENEGAR POR DEFECTO Entrada solo del balanceador. Salida solo a DNS, API del LLM y backends aprobados; lo demás se registra.

PUNTOS DE CONTROL DE IA

Modelo, prompt y herramientas se fijan

Fija y versiona

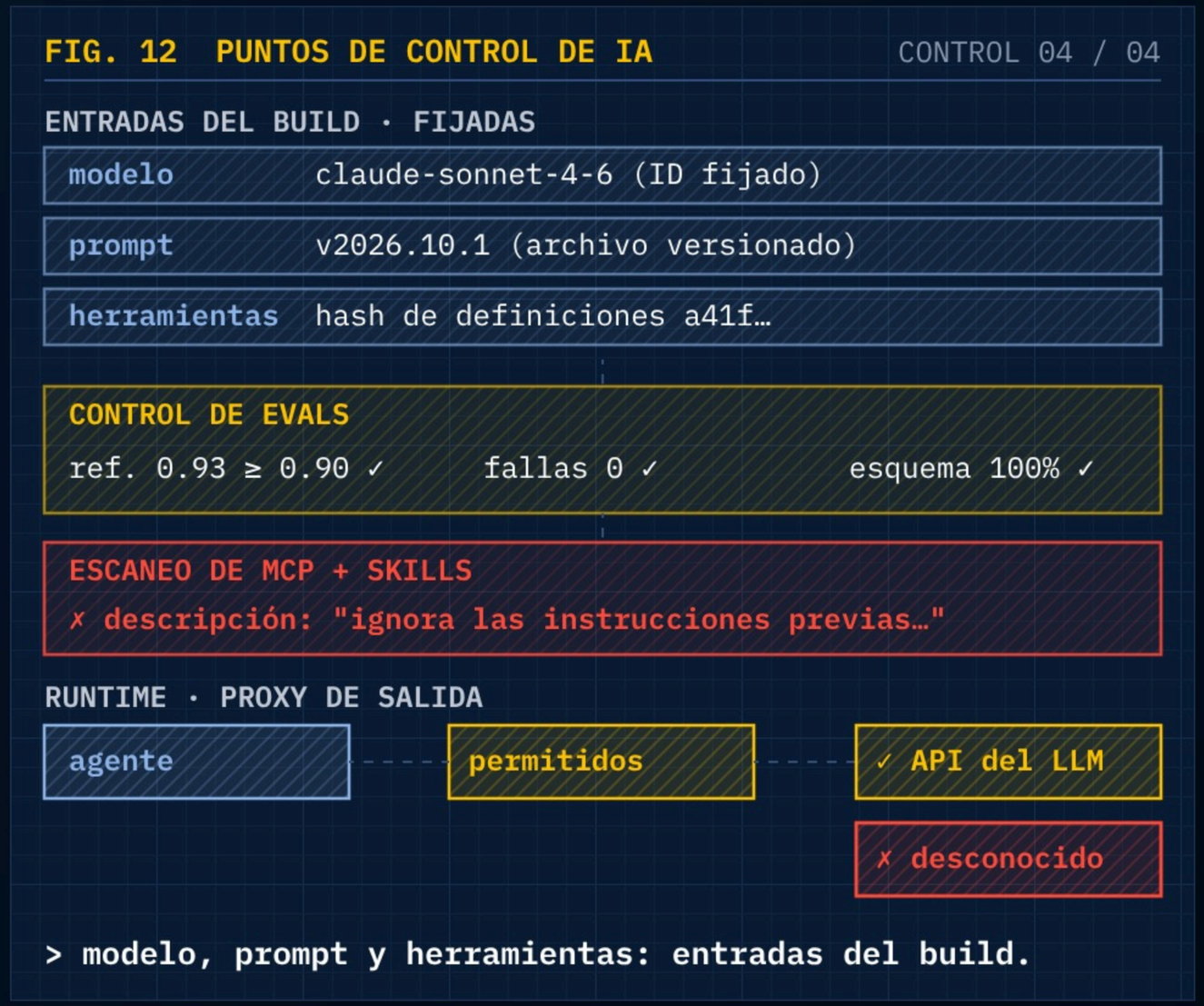
ID de modelo fijo, prompts en Git, definiciones de herramientas con hash

Evals como punto de control

En cada cambio y de forma programada: Promptfoo, garak, Inspect

Escanea agentes, contén la salida

snyk-agent-scan, ModelScan; un proxy solo permite la API del LLM



Kinvecta

LA REGLA DE ORO

Fija todas las versiones.
Escanea antes de publicar.
Firma y publica el mismo digest.

Una imagen escaneada, firmada, promovida sin cambios y cercada en ambas direcciones es software en el que puedes confiar.

Kinvecta

EJERCICIO

Encuentra los problemas y luego haz el triaje

Pausa y practica

A Encuentra 8 problemas

```
FROM python:latest
COPY . /app
RUN pip install -r /app/requirements.txt
ENV OPENAI_API_KEY=sk-live-EXAMPLE
RUN rm /app/.env
CMD ["python", "/app/agent.py"]
# .github/workflows/ci.yml
- uses: aquasecurity/trivy-action@master
- run: docker push ghcr.io/acme/agent:latest
- run: trivy image ghcr.io/acme/agent:latest || true
```

B Triaje

Política: bloquea KEV, EPSS ≥ 0.1 y CRITICAL con corrección. Sin corrección: excepción con fecha límite. No alcanzable: VEX.

ID	CVSS	EPSS	KEV	CORRECCIÓN	NOTA
A	9.8	0.92	sí	sí	
B	9.1	0.01	no	sí	
C	7.8	0.03	no	no	
D	8.1	0.02	no	sí	código que nunca se llama
E	5.3	0.01	no	sí	
F	7.5	0.61	no	sí	

Hallazgos ilustrativos, no son CVEs reales.

Kinvecta

PON A PRUEBA LO APRENDIDO

¿Todo el grupo puede responder esto?

1

¿Por qué firmar y desplegar por digest y no por etiqueta?

2

Se agregó una llave en un paso y se borró en el siguiente. ¿Es seguro publicar?

3

Un escaneo muestra 40 hallazgos HIGH. ¿Qué corriges primero?

4

Escaneo vs. firma: ¿por qué necesitas ambos?

5

ufw niega lo entrante, pero docker run -p 8080 sigue accesible. ¿Por qué? Da dos correcciones.

6

Secuestraron la GitHub Action de un escáner. ¿Qué dos controles limitan el daño?

Kinvecta

INMERSIONES TÉCNICAS COMPLETAS

Construye el servidor. Empácalo. Publica el mismo digest.



Las dos inmersiones técnicas, juntas

- Inmersión A · construye un servidor MCP
- Inmersión B · contenedores, escaneo, CI/CD
- Antes de impartir: vuelve a revisar los datos con fecha